

Hiện tại subdirectory admin

Trong web app của bạn, subdirectory `/admin` nên được dùng làm khu vực điều phối hệ thống — lý toàn bộ cấu hình, quyền, mapping công việc, benchmark, audit runner, release và các thiết lập và

`/admin` không phải nơi viết báo cáo hay chạy audit trực tiếp, mà là nơi quản trị nền tảng Re

1. /admin dùng để quản lý người dùng và phân q

Đây là chức năng quan trọng nhất.

/admin/users

Admin có thể xem danh sách user đăng nhập bằng GitHub:

- GitHub username
- avatar
- email nếu có
- role
- trạng thái active/inactive
- lần đăng nhập gần nhất

Role đề xuất

- 1 Admin
- 2 Leader
- 3 Member
- 4 Auditor
- 5 Viewer
- 6

ý nghĩa role

	≡ Role	≡ Quyền chính
1	Admin	Toàn quyền cấu hình hệ thống
2	Leader	Quản lý báo cáo, release, xem
3	Member	Chỉ sửa phần được giao
4	Auditor	Tạo target, chạy audit, xem au
5	Viewer	Chỉ xem report/audit result

2. /admin dùng để map thành viên với phần M1–

Vì nhóm bạn đã chia việc rõ:

- 1 M1: 1.1, 1.2, 1.4, 1.5, 1.6, 2.3, 2.4
- 2 M2: 1.3, 2.1, 2.2, 3, 4
- 3 M3: 5.1, 5.2, 5.3, 5.4
- 4 M4: 1.7, 1.8, 6, 7
- 5

Thì `/admin/sections` nên cho phép quản lý mapping này.

/admin/sections

Admin/Leader có thể:

- tạo section M1–M4
- gán người phụ trách
- gán các CIS section tương ứng

- đặt trạng thái:
 - Not started
 - In progress
 - Completed
 - Needs review
 - Approved
- xem file report section hiện tại
- xem lịch sử version

Ví dụ data:

```
1 {  
2   "section_key": "M1",  
3   "title": "Filesystem, Package, Boot, Process Hardening, Crypto, Time Sy  
4   "owner": "LQH",  
5   "cis_sections": ["1.1", "1.2", "1.4", "1.5", "1.6", "2.3", "2.4"]  
6 }  
7
```

3. /admin dùng để quản lý CIS Benchmark catalog

Đây là phần phục vụ tính năng **Auto-Audit**.

/admin/benchmarks

Admin có thể quản lý:

- benchmark name
- benchmark version
- OS target
- profile
- số lượng controls
- nguồn dữ liệu:

- - - -

- OpenSCAP
- custom JSON
- manual mapping từ PDF

Ví dụ:

```
1 CIS AlmaLinux OS 9 Benchmark v2.0.0
2 Profile: Level 1 - Server
3
```

4. /admin dùng để quản lý controls/rules

/admin/controls

Đây là nơi quản lý từng rule CIS.

Ví dụ:

```
1 1.1.1.1 Ensure cramfs kernel module is not available
2 1.1.2.1.2 Ensure nodev option set on /tmp partition
3 5.1.20 Ensure sshd PermitRootLogin is disabled
4 6.3.1.4 Ensure auditd service is enabled and active
5
```

Admin có thể:

- bật/tắt rule
- đánh dấu rule là Automated/Manual
- gán rule cho M1–M4
- gán mức risk
- map rule với OpenSCAP rule ID
- thêm remediation note
- thêm explanation cho báo cáo

- thêm explanation cho báo cáo

Ví dụ:

```
1 {
2   "control_id": "5.1.20",
3   "title": "Ensure sshd PermitRootLogin is disabled",
4   "owner_section": "M3",
5   "risk": "Critical",
6   "automated": true,
7   "enabled": true
8 }
9
```

5. /admin dùng để quản lý audit targets

Phần nhập IP/credential để chạy audit nên nằm ở `/audit`, nhưng phần quản trị target có thể nằm

/admin/audit-targets

Admin/Auditor có thể:

- xem danh sách máy đã đăng ký
- xoá target
- đổi tên target
- gắn tag môi trường:
 - lab
 - staging
 - production
- xem lần audit gần nhất
- xem compliance trend

Ví dụ:

```
1 alma-lab-01
2 IP: 192.168.56.10
3 OS: AlmaLinux 9
4 Last audit: 78% compliant
5 Risk: Medium
6
```

6. /admin dùng để quản lý credential policy

Đây là phần rất quan trọng về bảo mật.

/admin/credentials

Không nên hiển thị lại password/private key. Chỉ nên hiển thị metadata:

```
1 Target: alma-lab-01
2 Credential type: SSH key
3 Created by: Leader
4 Expires at: 2026-05-10
5 Storage: Vault
6
```

Admin có thể:

- revoke credential
- set TTL
- yêu cầu credential one-time
- bật/tắt lưu credential
- cấu hình vault provider

Chính sách nên có

```
1 - Không lưu plaintext password
2 - Không log private key
```

- 2 - không log private key
- 3 - Credential có TTL
- 4 - Có audit log khi credential được tạo/xoá/sử dụng
- 5

7. /admin dùng để quản lý Audit Runner

Vì audit SSH/OpenSCAP nên chạy ở worker riêng, `/admin/runners` sẽ quản lý trạng thái runner.

/admin/runners

Hiển thị:

- runner name
- status:
 - online
 - offline
 - busy
 - error
- version
- last heartbeat
- installed tools:
 - oscap
 - scap-security-guide
 - ssh client
- queue length

Ví dụ:

```
1 runner-01
2 Status: Online
3 OpenSCAP: Installed
4 SCAP Security Guide: AlmaLinux 9 available
5 Current jobs: 0
```


8. /admin dùng để quản lý release settings

/admin/release-settings

Admin/Leader có thể cấu hình:

- release naming convention
- GitHub repository target
- artifact retention
- auto attach audit result hay không
- final report format:
 - DOCX
 - PDF
 - HTML
 - JSON

Ví dụ:

```
1 Release format:
2 ReportOps-v{version}-{date}
3
4 Artifacts:
5 - Final Report PDF
6 - Final Report DOCX
7 - Audit Summary JSON
8 - Audit HTML Report
9
```

9. /admin dùng để xem audit logs

/admin/audit-logs

Đây là log của chính web app, không phải CIS audit result.

Ghi lại các hành động như:

```
1 User LQH logged in
2 Leader assigned M3 to Truong Duy
3 Auditor created target alma-lab-01
4 Runner started audit job #123
5 Admin revoked credential for target alma-lab-01
6 Leader froze release v1.0.0
7
```

Mục đích:

- truy vết
- bảo vệ hệ thống
- hỗ trợ thuyết minh DevSecOps
- phát hiện misuse

10. /admin dùng để quản lý system settings

/admin/settings

Các cấu hình toàn hệ thống:

GitHub OAuth

```
1 Client ID
2 Callback URL
3 Allowed org/users
4
```

ONLYOFFICE

- 1 Document Server URL
- 2 JWT secret enabled/disabled
- 3 Callback URL base
- 4

Storage

- 1 Blob provider
- 2 Bucket/container name
- 3 Retention policy
- 4

Audit

- 1 Default benchmark
- 2 Default profile: CIS AlmaLinux 9 L1 Server
- 3 Max concurrent jobs
- 4 Credential TTL
- 5

11. /admin không nên dùng để làm gì?

Để hệ thống sạch, bạn không nên để `/admin` làm các việc sau:

≡ Không nên	≡ Nên đặt ở
-------------	-------------

1	Member viết báo cáo	<u>/reports</u>
2	Member mở ONLYOFFICE editor	<u>/reports/[section]</u>
3	Người dùng nhập IP để audit	<u>/audit/new</u>
4	Xem audit dashboard	<u>/audit/results/[jobId]</u>
5	Xem final report	<u>/releases</u>

`/admin` chỉ nên dành cho **quản trị**, không dành cho workflow thường ngày.

12. Cấu trúc /admin mình đề xuất

```
1 /admin
2 |— /overview
3 |— /users
4 |— /roles
5 |— /sections
6 |— /benchmarks
7 |— /controls
8 |— /audit-targets
9 |— /credentials
10 |— /runners
11 |— /release-settings
12 |— /audit-logs
13 |— /settings
14
```

13. Mức ưu tiên MVP cho /admin

Nếu làm MVP, bạn không cần làm hết ngay.

MVP bắt buộc

```
1 /admin/users
2 /admin/sections
3 /admin/controls
4 /admin/audit-targets
5 /admin/settings
6
```

Sau MVP

```
1 /admin/runners
2 /admin/credentials
3 /admin/release-settings
4 /admin/audit-logs
5
```

Kết luận

Trong web app của bạn, `/admin` nên là trung tâm quản trị cho cả hai module:

ReportOps

- quản lý user
- quản lý M1–M4
- quản lý quyền sửa report
- quản lý release settings

Auto-Audit

- quản lý benchmark
- quản lý CIS controls

quản lý cis controls

- quản lý mapping controls → M1–M4
- quản lý audit targets
- quản lý runners
- quản lý credential policy

Nói ngắn gọn:

/admin = nơi cấu hình và điều phối toàn bộ hệ thống.

/reports = nơi viết báo cáo.

/audit = nơi chạy audit.

/releases = nơi xem bản final và artifacts.